

OWASP ZAP Scan Report

Target: https://nilvan.duckdns.org/

All scanned sites: https://nilvan.duckdns.org

Javascript included from: https://nilvan.duckdns.org

Generated on Sat, 9 May 2026 06:47:34

ZAP Version: 2.17.0

Summary of Alerts

| Risk Level    | Number of Alerts |
|---------------|------------------|
| High          | 0                |
| Medium        | 6                |
| Low           | 2                |
| Informational | 2                |

Alerts

| Name                                                                                      | Risk Level    | Number of Instances |
|-------------------------------------------------------------------------------------------|---------------|---------------------|
| <a href="#">CSP: Failure to Define Directive with No Fallback</a>                         | Medium        | 5                   |
| <a href="#">CSP: Wildcard Directive</a>                                                   | Medium        | 5                   |
| <a href="#">CSP: script-src unsafe-eval</a>                                               | Medium        | 5                   |
| <a href="#">CSP: script-src unsafe-inline</a>                                             | Medium        | 5                   |
| <a href="#">CSP: style-src unsafe-inline</a>                                              | Medium        | 5                   |
| <a href="#">Sub Resource Integrity Attribute Missing</a>                                  | Medium        | 2                   |
| <a href="#">Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)</a> | Low           | 5                   |
| <a href="#">Server Leaks Version Information via "Server" HTTP Response Header Field</a>  | Low           | 5                   |
| <a href="#">Information Disclosure - Sensitive Information in URL</a>                     | Informational | 1                   |
| <a href="#">Re-examine Cache-control Directives</a>                                       | Informational | 2                   |

Passing Rules

| Name                                                           | Rule Type | Threshold | Strength |
|----------------------------------------------------------------|-----------|-----------|----------|
| <a href="#">Session Management Response Identified</a>         | Passive   | MEDIUM    | -        |
| <a href="#">Verification Request Identified</a>                | Passive   | MEDIUM    | -        |
| <a href="#">Private IP Disclosure</a>                          | Passive   | MEDIUM    | -        |
| <a href="#">Session ID in URL Rewrite</a>                      | Passive   | MEDIUM    | -        |
| <a href="#">Script Served From Malicious Domain (polyfill)</a> | Passive   | MEDIUM    | -        |
| <a href="#">ZAP is Out of Date</a>                             | Passive   | MEDIUM    | -        |
| <a href="#">Insecure JSF ViewState</a>                         | Passive   | MEDIUM    | -        |
| <a href="#">Vulnerable JS Library (Powered by Retire.js)</a>   | Passive   | MEDIUM    | -        |
| <a href="#">Java Serialization Object</a>                      | Passive   | MEDIUM    | -        |
| <a href="#">In Page Banner Information Leak</a>                | Passive   | MEDIUM    | -        |
| <a href="#">Charset Mismatch</a>                               | Passive   | MEDIUM    | -        |
| <a href="#">Cookie No HttpOnly Flag</a>                        | Passive   | MEDIUM    | -        |
| <a href="#">Cookie Without Secure Flag</a>                     | Passive   | MEDIUM    | -        |
| <a href="#">Cross-Domain JavaScript Source File Inclusion</a>  | Passive   | MEDIUM    | -        |

|                                                                                        |         |        |   |
|----------------------------------------------------------------------------------------|---------|--------|---|
| <a href="#">Content-Type Header Missing</a>                                            | Passive | MEDIUM | - |
| <a href="#">Anti-clickjacking Header</a>                                               | Passive | MEDIUM | - |
| <a href="#">X-Content-Type-Options Header Missing</a>                                  | Passive | MEDIUM | - |
| <a href="#">Application Error Disclosure</a>                                           | Passive | MEDIUM | - |
| <a href="#">Information Disclosure - Debug Error Messages</a>                          | Passive | MEDIUM | - |
| <a href="#">Information Disclosure - Sensitive Information in HTTP Referrer Header</a> | Passive | MEDIUM | - |
| <a href="#">Information Disclosure - Suspicious Comments</a>                           | Passive | MEDIUM | - |
| <a href="#">Off-site Redirect</a>                                                      | Passive | MEDIUM | - |
| <a href="#">Cookie Poisoning</a>                                                       | Passive | MEDIUM | - |
| <a href="#">User Controllable Charset</a>                                              | Passive | MEDIUM | - |
| <a href="#">User Controllable HTML Element Attribute (Potential XSS)</a>               | Passive | MEDIUM | - |
| <a href="#">WSDL File Detection</a>                                                    | Passive | MEDIUM | - |
| <a href="#">Loosely Scoped Cookie</a>                                                  | Passive | MEDIUM | - |
| <a href="#">Viewstate</a>                                                              | Passive | MEDIUM | - |
| <a href="#">Directory Browsing</a>                                                     | Passive | MEDIUM | - |
| <a href="#">Heartbleed OpenSSL Vulnerability (Indicative)</a>                          | Passive | MEDIUM | - |
| <a href="#">Strict-Transport-Security Header</a>                                       | Passive | MEDIUM | - |
| <a href="#">Content Security Policy (CSP) Header Not Set</a>                           | Passive | MEDIUM | - |
| <a href="#">X-Backend-Server Header Information Leak</a>                               | Passive | MEDIUM | - |
| <a href="#">Secure Pages Include Mixed Content</a>                                     | Passive | MEDIUM | - |
| <a href="#">HTTP to HTTPS Insecure Transition in Form Post</a>                         | Passive | MEDIUM | - |
| <a href="#">HTTPS to HTTP Insecure Transition in Form Post</a>                         | Passive | MEDIUM | - |
| <a href="#">User Controllable JavaScript Event (XSS)</a>                               | Passive | MEDIUM | - |
| <a href="#">Big Redirect Detected (Potential Sensitive Information Leak)</a>           | Passive | MEDIUM | - |
| <a href="#">Retrieved from Cache</a>                                                   | Passive | MEDIUM | - |
| <a href="#">X-ChromeLogger-Data (XCOLD) Header Information Leak</a>                    | Passive | MEDIUM | - |
| <a href="#">Cookie without SameSite Attribute</a>                                      | Passive | MEDIUM | - |
| <a href="#">X-Debug-Token Information Leak</a>                                         | Passive | MEDIUM | - |
| <a href="#">Username Hash Found</a>                                                    | Passive | MEDIUM | - |
| <a href="#">X-AspNet-Version Response Header</a>                                       | Passive | MEDIUM | - |
| <a href="#">PII Disclosure</a>                                                         | Passive | MEDIUM | - |
| <a href="#">Script Passive Scan Rules</a>                                              | Passive | MEDIUM | - |
| <a href="#">Stats Passive Scan Rule</a>                                                | Passive | MEDIUM | - |
| <a href="#">Absence of Anti-CSRF Tokens</a>                                            | Passive | MEDIUM | - |
| <a href="#">Timestamp Disclosure</a>                                                   | Passive | MEDIUM | - |
| <a href="#">Hash Disclosure</a>                                                        | Passive | MEDIUM | - |
| <a href="#">Cross-Domain Misconfiguration</a>                                          | Passive | MEDIUM | - |
| <a href="#">Weak Authentication Method</a>                                             | Passive | MEDIUM | - |
| <a href="#">Reverse Tabnabbing</a>                                                     | Passive | MEDIUM | - |
| <a href="#">Modern Web Application</a>                                                 | Passive | MEDIUM | - |
| <a href="#">Authentication Request Identified</a>                                      | Passive | MEDIUM | - |

Alert Detail

|             |                                                                                                                                                                                                                                           |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium      | CSP: Failure to Define Directive with No Fallback                                                                                                                                                                                         |
| Description | The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.                                                                                          |
| URL         | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                     |
| Method      | GET                                                                                                                                                                                                                                       |
| Parameter   | Content-Security-Policy                                                                                                                                                                                                                   |
| Attack      |                                                                                                                                                                                                                                           |
| Evidence    | default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info                | The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Request Header            | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Request Body              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Response Header           | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                                                                                                                                                      |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info                | The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info                | The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| URL                       | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info                | The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| URL                       | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Other Info                | The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances                 | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution                  | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Reference                 | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a>                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| CWE Id                    | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| WASC Id                   | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Plugin Id                 | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Medium                    | CSP: Wildcard Directive                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Description               | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.                                                                                                                                                                                                                                                                                                                |
| URL                       | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Other Info                | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, worker-src                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Request Header            | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Request Body              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Response Header           | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000,<br>ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: <b>default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;</b> |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Other Info                | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, worker-src                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

|                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| URL             | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Method          | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter       | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence        | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info      | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, worker-src                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL             | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method          | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter       | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence        | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info      | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, worker-src                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL             | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Method          | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter       | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence        | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info      | The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, worker-src                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Instances       | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Solution        | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Reference       | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a>                                                                                                                            |
| CWE Id          | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| WASC Id         | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Plugin Id       | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Medium          | CSP: script-src unsafe-eval                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Description     | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
|                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| URL             | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method          | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Parameter       | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Attack          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidence        | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                          |
| Other Info      | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Request Header  | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                 |
| Request Body    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Response Header | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive                                                                                                                                                                                                                                                                                                                                                                                                                                               |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                           | Vary: RSC; Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: <b>default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https:; connect-src 'self' https:; frame-src 'self' https:; font-src 'self' data: https;;</b> |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charset="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                     |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https:; connect-src 'self' https:; frame-src 'self' https:; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info                | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https:; connect-src 'self' https:; frame-src 'self' https:; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info                | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL                       | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https:; connect-src 'self' https:; frame-src 'self' https:; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info                | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL                       | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https:; connect-src 'self' https:; frame-src 'self' https:; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Other Info                | script-src includes unsafe-eval.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Instances                 | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Solution                  | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Reference                 | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a>                                                                                                                                                                                                                                                |
| CWE Id                    | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| WASC Id                   | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Plugin Id                 | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Medium                    | CSP: script-src unsafe-inline                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description                        | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.                                                                                                                                                                                                                                                                                                             |
| URL                                | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method                             | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter                          | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence                           | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info                         | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Request Header                     | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Request Body                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Response Header                    | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: <b>default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;</b> |
| Response Body ( <b>truncated</b> ) | <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL                                | <a href="https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Method                             | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter                          | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence                           | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info                         | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL                                | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Method                             | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter                          | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidence                           | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Other Info                         | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| URL                                | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Method                             | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Parameter                          | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Attack                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| URL        | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | script-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Instances  | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium                    | CSP: style-src unsafe-inline                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Description               | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.                                                                                                                                                                                                                                                                                                      |
| URL                       | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Other Info                | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Request Header            | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Request Body              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Response Header           | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/m                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|            | edia/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                      |
| URL        | <a href="https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2FNilavan-Realtors-Logo.png&amp;w=256&amp;q=75</a>                                                                                                                                                                                                                                                                                                                   |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL        | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                     |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL        | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                               |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| URL        | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method     | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter  | Content-Security-Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Attack     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence   | default-src 'self'; img-src 'self' data: https: blob:; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;;                                                                                                                                                                                                                                                               |
| Other Info | style-src includes unsafe-inline.                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Instances  | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution   | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.                                                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a><br><a href="https://caniuse.com/#search=content+security+policy">https://caniuse.com/#search=content+security+policy</a><br><a href="https://content-security-policy.com/">https://content-security-policy.com/</a><br><a href="https://github.com/HtmlUnit/htmlunit-csp">https://github.com/HtmlUnit/htmlunit-csp</a><br><a href="https://web.dev/articles/csp#resource-options">https://web.dev/articles/csp#resource-options</a> |
| CWE Id     | <a href="#">693</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id    | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id  | <a href="#">10055</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|                |                                                                                                                                                                                                                                                    |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium         | Sub Resource Integrity Attribute Missing                                                                                                                                                                                                           |
| Description    | The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.                                          |
| URL            | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                              |
| Method         | GET                                                                                                                                                                                                                                                |
| Parameter      |                                                                                                                                                                                                                                                    |
| Attack         |                                                                                                                                                                                                                                                    |
| Evidence       | <link rel="preload" as="image" href="/images/Laedtap Favicon.png"/>                                                                                                                                                                                |
| Other Info     |                                                                                                                                                                                                                                                    |
| Request Header | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache |

|                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Request Body            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Response Header         | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (excerpt) | async=""></script><script src="/_next/static/chunks/538-8b922a30b526a6b9.js" async=""></script><script src="/_next/static/chunks/app/page-b11686141ac81cc8.js" async=""></script><link rel="preload" as="image" href="/images/Nilavan-Realtors-Logo.png"/><link rel="preload" as="image" href="/images/Laedtap Favicon.png"/><meta name="next-size-adjust" content=""/><title>Nilavan Realtors - Find Your Dream Property in Coimbatore</title><meta name="description" content="Discover premium residential and commercial properties in Coimbatore with Nilavan Realtors, your trust                                                                                                                                                                                                                                                                                                                                                 |
| URL                     | <a href="https://nilvan.duckdns.org/2email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999">https://nilvan.duckdns.org/2email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method                  | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Attack                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                | <link rel="preload" as="image" href="/images/Laedtap Favicon.png"/>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Instances               | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution                | Provide a valid integrity attribute to the tag.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Reference               | <a href="https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity">https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| CWE Id                  | <a href="#">345</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id                 | 15                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id               | <a href="#">90003</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|                 |                                                                                                                                                                                                                                                                                                     |
|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Low             | Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)                                                                                                                                                                                                                           |
| Description     | The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to. |
| URL             | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                               |
| Method          | GET                                                                                                                                                                                                                                                                                                 |
| Parameter       |                                                                                                                                                                                                                                                                                                     |
| Attack          |                                                                                                                                                                                                                                                                                                     |
| Evidence        | X-Powered-By: Next.js                                                                                                                                                                                                                                                                               |
| Other Info      |                                                                                                                                                                                                                                                                                                     |
| Request Header  | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                  |
| Request Body    |                                                                                                                                                                                                                                                                                                     |
| Response Header | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445                                                                                                                                          |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                           | Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br><b>X-Powered-By: Next.js</b><br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charset="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                               |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=640&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Parameter                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence                  | X-Powered-By: Next.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| URL                       | <a href="https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=828&amp;q=75">https://nilvan.duckdns.org/%2Fimages%2Favailable-plot-image.png&amp;w=828&amp;q=75</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Parameter                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence                  | X-Powered-By: Next.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| URL                       | <a href="https://nilvan.duckdns.org/robots.txt">https://nilvan.duckdns.org/robots.txt</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Parameter                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence                  | X-Powered-By: Next.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| URL                       | <a href="https://nilvan.duckdns.org/sitemap.xml">https://nilvan.duckdns.org/sitemap.xml</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Parameter                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Evidence                  | X-Powered-By: Next.js                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Instances                 | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Solution                  | Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Reference                 | <a href="https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework">https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework</a><br><a href="https://www.troyhunt.com/shhh-dont-let-your-response-headers/">https://www.troyhunt.com/shhh-dont-let-your-response-headers/</a>                                                                                                                                                                                                                                                                                   |
| CWE Id                    | <a href="#">497</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| WASC Id                   | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Plugin Id                 | <a href="#">10037</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Low                       | Server Leaks Version Information via "Server" HTTP Response Header Field                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Description               | The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL                       | <a href="https://nilvan.duckdns.org/_next/static/media/0484562807a97172-s.p.woff2">https://nilvan.duckdns.org/_next/static/media/0484562807a97172-s.p.woff2</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |



|            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Evidence   | nginx/1.28.3 (Ubuntu)                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Other Info |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Instances  | 5                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Solution   | Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.                                                                                                                                                                                                                                                                                                                                  |
| Reference  | <a href="https://httpd.apache.org/docs/current/mod/core.html#servertokens">https://httpd.apache.org/docs/current/mod/core.html#servertokens</a><br><a href="https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)">https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)</a><br><a href="https://www.troyhunt.com/shhh-dont-let-your-response-headers/">https://www.troyhunt.com/shhh-dont-let-your-response-headers/</a> |
| CWE Id     | <a href="#">497</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| WASC Id    | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Plugin Id  | <a href="#">10036</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

| Informational             | Information Disclosure - Sensitive Information in URL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description               | The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL                       | <a href="https://nilvan.duckdns.org/?email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999">https://nilvan.duckdns.org/?email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Parameter                 | email                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidence                  | zaproxy@example.com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Other Info                | The URL contains email address(es).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Request Header            | GET https://nilvan.duckdns.org/?email=zaproxy%40example.com&message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&phone=9999999999 HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache<br>referer: https://nilvan.duckdns.org/                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Request Body              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Response Header           | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:32 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: s-maxage=31536000, ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                                                                                                                                                      |
| Instances                 | 1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Solution                  | Do not pass sensitive information in URIs.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Reference                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| CWE Id                    | <a href="#">598</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| WASC Id                   | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Plugin Id                 | <a href="#">10024</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

| Informational             | Re-examine Cache-control Directives                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description               | The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| URL                       | <a href="https://nilvan.duckdns.org/">https://nilvan.duckdns.org/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter                 | cache-control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence                  | s-maxage=31536000,                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Request Header            | GET https://nilvan.duckdns.org/ HTTP/1.1<br>host: nilvan.duckdns.org<br>user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36<br>pragma: no-cache<br>cache-control: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Request Body              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Response Header           | HTTP/1.1 200 OK<br>Server: nginx/1.28.3 (Ubuntu)<br>Date: Sat, 09 May 2026 06:46:25 GMT<br>Content-Type: text/html; charset=utf-8<br>Content-Length: 47445<br>Connection: keep-alive<br>Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding<br>x-nextjs-cache: HIT<br>x-nextjs-prerender: 1<br>x-nextjs-stale-time: 4294967294<br>X-Powered-By: Next.js<br>Cache-Control: <b>s-maxage=31536000,</b><br>ETag: "qgpwlta4ao10lu"<br>X-Frame-Options: DENY<br>X-Content-Type-Options: nosniff<br>Referrer-Policy: strict-origin-when-cross-origin<br>Strict-Transport-Security: max-age=63072000; includeSubDomains; preload<br>Content-Security-Policy: default-src 'self'; img-src 'self' data: https: blob;; style-src 'self' 'unsafe-inline' https;; script-src 'self' 'unsafe-inline' 'unsafe-eval' https;; connect-src 'self' https;; frame-src 'self' https;; font-src 'self' data: https;; |
| Response Body (truncated) | <!DOCTYPE html><html lang="en"><head><meta charset="utf-8"/><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" href="/_next/static/media/0484562807a97172-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/4c285fdca692ea22-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preload" href="/_next/static/media/8888a3826f4a3af4-s.p.woff2" as="font" crossorigin="" type="font/woff2"/><link rel="preloa...(truncated)                                                                                                                                                                                                                                                                                                                                                                                                                |
| URL                       | <a href="https://nilvan.duckdns.org/?email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999">https://nilvan.duckdns.org/?email=zaproxy%40example.com&amp;message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&amp;name=ZAP&amp;phone=9999999999</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Method                    | GET                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Parameter                 | cache-control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Attack                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Evidence                  | s-maxage=31536000,                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Other Info                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Instances                 | 2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Solution                  | For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Reference                 | <a href="https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching">https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching</a><br><a href="https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control">https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control</a><br><a href="https://grayduck.mn/2021/09/13/cache-control-recommendations/">https://grayduck.mn/2021/09/13/cache-control-recommendations/</a>                                                                                                                                                                                                                                                                                                                                                                                     |
| CWE Id                    | <a href="#">525</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| WASC Id                   | 13                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Plugin Id                 | <a href="#">10015</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |